

Marco integrativo GQM + PRAGMATIC aplicado a FAIR-STRIDE

1. Propósito del marco

Este marco integra la metodología GQM (Goal-Question-Metric) con los criterios PRAGMATIC para el diseño, evaluación y gobierno de indicadores FAIR-STRIDE a nivel nacional, sectorial y organizativo.

El objetivo es asegurar trazabilidad explícita desde:

- Objetivos nacionales de ciberresiliencia (por ejemplo, reducción de pérdidas económicas, mejora de continuidad de servicios esenciales, cumplimiento regulatorio).
- Preguntas de gestión que los responsables políticos y ejecutivos necesitan responder.
- Métricas técnicas concretas, evaluadas bajo los nueve criterios PRAGMATIC: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable.

2. Estructura GQM aplicada a FAIR-STRIDE

2.1 Niveles de objetivos

Se distinguen tres niveles:

1. **Objetivos estratégicos nacionales**
Ejemplo: “Reducir la pérdida económica anual esperada por incidentes de ciberseguridad que afecten a servicios esenciales en España”.
2. **Objetivos tácticos sectoriales/organizativos**
Ejemplo: “Disminuir la frecuencia y el impacto de incidentes de disponibilidad en el sector sanitario en un 30 % en tres años”.
3. **Objetivos operativos técnicos (FAIR-STRIDE)**
Ejemplo: “Reducir en un 50 % los incidentes de suplantación de identidad con impacto económico superior a X euros, en sistemas críticos autenticados”.

Objetivos estratégicos nacionales

Ejemplo: “Reducir la pérdida económica anual esperada por incidentes de ciberseguridad que afecten a servicios esenciales en España”.

Objetivos tácticos sectoriales/organizativos

Ejemplo: “Disminuir la frecuencia y el impacto de incidentes de disponibilidad en el sector sanitario en un 30 % en tres años”.

Objetivos operativos técnicos (FAIR-STRIDE)

Ejemplo: “Reducir en un 50 % los incidentes de suplantación de identidad con impacto económico superior a X euros, en sistemas críticos autenticados”.

2.2 Esquema GQM

Para cada objetivo se definen:

- Goal (Objetivo): qué se quiere lograr, desde qué perspectiva y en qué contexto.
- Question (Preguntas): qué queremos saber para juzgar si el objetivo se cumple.
- Metric (Métricas): qué datos concretos recopilamos para responder a las preguntas.

Ejemplo resumido para Autenticidad:

- Goal: “Mejorar la autenticidad de las identidades digitales críticas para reducir la pérdida anual esperada derivada de fraudes y accesos no autorizados”.
- Questions:
 - Q1: ¿Con qué frecuencia se producen incidentes de suplantación de identidad en sistemas críticos?
 - Q2: ¿Cuál es la pérdida económica asociada a dichos incidentes?
 - Q3: ¿Qué relación hay entre controles de autenticación fuerte y reducción de pérdida?
- Metrics:
 - M1: Número de cuentas comprometidas en sistemas críticos por periodo.
 - M2: Pérdida económica anual esperada por incidentes de suplantación (distribución FAIR).
 - M3: Porcentaje de transacciones críticas protegidas por MFA/FIDO2, etc.

3. Dimensiones FAIR-STRIDE y GQM

Para cada propiedad FAIR-STRIDE se propone un objetivo genérico GQM:

4.

Autenticidad

Goal: “Reducir la pérdida anual esperada asociada a suplantación de identidad en activos críticos”.

5.

Integridad

Goal: “Minimizar la pérdida anual esperada por alteraciones de integridad que afecten a decisiones operativas, financieras o clínicas”.

6.

No repudio

Goal: “Reducir la exposición a pérdidas por disputas, fraudes o sanciones derivadas de falta de evidencia fiable sobre quién hizo qué y cuándo”.

7.

Confidencialidad

Goal: “Disminuir la pérdida anual esperada derivada de violaciones de confidencialidad de datos personales, financieros o estratégicos”.

8.

Disponibilidad

Goal: “Limitar la pérdida anual esperada por interrupciones de servicios críticos por causas cibernéticas u operativas”.

9.

Autorización (elevación/abuso de privilegios)

Goal: “Reducir la pérdida anual esperada asociada a abusos de privilegios y accesos indebidos a información y funciones críticas”.

Autenticidad

Goal: “Reducir la pérdida anual esperada asociada a suplantación de identidad en activos críticos”.

Integridad

Goal: “Minimizar la pérdida anual esperada por alteraciones de integridad que afecten a decisiones operativas, financieras o clínicas”.

No repudio

Goal: “Reducir la exposición a pérdidas por disputas, fraudes o sanciones derivadas de falta de evidencia fiable sobre quién hizo qué y cuándo”.

Confidencialidad

Goal: “Disminuir la pérdida anual esperada derivada de violaciones de confidencialidad de datos personales, financieros o estratégicos”.

Disponibilidad

Goal: “Limitar la pérdida anual esperada por interrupciones de servicios críticos por causas cibernéticas u operativas”.

Autorización (elevación/abuso de privilegios)

Goal: “Reducir la pérdida anual esperada asociada a abusos de privilegios y accesos indebidos a información y funciones críticas”.

Para cada Goal se derivan:

- Preguntas de gestión (dirigidas a CISOs, reguladores, responsables sectoriales).
- Métricas técnicas y de negocio (input para modelos FAIR y seguimiento operativo).

4. Criterios PRAGMATIC: definición resumida

Cada métrica se evalúa con una puntuación (por ejemplo, 0-5) en estos criterios:

- Predictivo: ¿ayuda a anticipar futuros incidentes o pérdidas, no sólo a describir el pasado?
- Relevante: ¿está directamente relacionado con los objetivos de negocio o nacionales?
- Accionable: ¿puede conducir a decisiones claras y cambios concretos?
- Genuino: ¿mide lo que dice medir, sin proxy engañosos?
- Significativo: ¿su variación es interpretativamente clara (no ruido)?
- Preciso: ¿posee suficiente exactitud/resolución para comparar en el tiempo o entre entidades?
- Oportuno: ¿se obtiene con una frecuencia adecuada para la decisión?
- Independiente: ¿no está excesivamente sesgada por manipulación o incentivos perversos?
- Rentable: ¿su coste de obtención y mantenimiento es razonable frente al valor que aporta?

5. Proceso integrativo GQM + PRAGMATIC

Para cada indicador FAIR-STRIDE se sigue este flujo:

10. Definir el Goal (nivel nacional/sectorial/organizativo).
11. Formular preguntas de gestión (Questions) que el indicador debe ayudar a responder.
12. Proponer una o más Métricas candidatas.
13. Evaluar cada métrica con los nueve criterios PRAGMATIC, asignando score y breve justificación.
14. Seleccionar el conjunto de métricas que maximicen valor PRAGMATIC, evitando redundancias.
15. Documentar trazabilidad Goal-Question-Metric-PRAGMATIC en una ficha estándar.
16. Revisar periódicamente la idoneidad de las métricas según evolución tecnológica, normativa y de amenazas.

6. Ejemplo de ficha GQM + PRAGMATIC (Autenticidad)

- Goal: Reducir en un X % la pérdida anual esperada por suplantación de identidad en servicios esenciales.
- Questions:
 - Q1: ¿Qué frecuencia de incidentes de suplantación registramos anualmente por tipo de servicio?
 - Q2: ¿Qué pérdida económica (media y percentiles) asociamos a esos incidentes?
 - Q3: ¿Cómo evoluciona la relación entre % de MFA fuerte y pérdidas por suplantación?
- Metric M1: N° de cuentas comprometidas en sistemas/servicios críticos por año.
- Metric M2: Pérdida anual esperada (FAIR) por suplantación, en euros, con distribución (media, p50, p90).
- Metric M3: % de transacciones críticas protegidas por MFA/FIDO2 o equivalente.

Q3: ¿Cómo evoluciona la relación entre % de MFA fuerte y pérdidas por suplantación?

Metric M1: N° de cuentas comprometidas en sistemas/servicios críticos por año.

Cada métrica se evalúa en PRAGMATIC (por ejemplo, escala 0-5) y se documenta la justificación.

7. Gobernanza del marco

- Nivel nacional: define Goals y Questions de alto nivel, y recomienda un set mínimo de métricas FAIR-STRIDE comunes para España.
- Nivel sectorial: especializa métricas y umbrales para banca, energía, salud, administración, etc.
- Nivel organizativo: concreta datos y fuentes, ajusta pesos y define objetivos propios coherentes con los nacionales.

El resultado es un sistema de indicadores donde cada número tiene “DNI”: se sabe qué objetivo persigue, qué pregunta contesta y qué decisiones soporta.